

Encuesta CSCR — Bloques VII–XI (Continuación)

Versión 1.0 · España · Abril 2026

BLOQUE VII — Evaluación Tecnológica: SBOM, PQC e IA en la Cadena de Suministro (continuación)

P7.6. ¿Su organización exige a los proveedores que integran IA/ML en sus servicios la entrega de un **AIBOM** (*AI Bill of Materials* — inventario de componentes de IA: modelos, datos de entrenamiento, frameworks, APIs externas)?

- ☐ Sí, para todos los proveedores con componentes IA/ML críticos, con actualización ante cada cambio de modelo.
- ☐ Lo estamos incorporando como requisito en los nuevos contratos a partir de 2026.
- ☐ Conocemos el concepto, pero no lo hemos implementado todavía.
- ☐ No conocemos el concepto de AIBOM ni sus implicaciones para la cadena de suministro.
- ☐ Consideramos que la responsabilidad sobre la IA del proveedor es exclusivamente del proveedor.
(Nota: esa tranquilizadora convicción no figura en ningún contrato auditado.)

P7.7. ¿Se verifica la **integridad de los artefactos de software o modelos de IA** entregados por los proveedores mediante checksums, firmas digitales o cadena de custodia criptográfica?

- ☐ Sí, de forma automatizada para todos los artefactos críticos, integrado en el pipeline CI/CD.
- ☐ Sí, de forma manual para los entregables más críticos.
- ☐ Solo verificamos la autenticidad del origen del proveedor, no la integridad del artefacto.
- ☐ No realizamos verificación de integridad de los artefactos de los proveedores.
- ☐ No sabíamos que esto debía verificarse. (Nota: bienvenido al mundo de los ataques a la cadena de suministro de software.)

P7.8. ¿Existe en su organización un proceso para detectar y gestionar el **drift** (desviación no autorizada del comportamiento) de los modelos de IA suministrados por terceros tras su puesta en producción?

- ☐ Sí, con monitorización continua de métricas de comportamiento del modelo y alertas automáticas ante desviaciones.
- ☐ Se realizan revisiones periódicas manuales del comportamiento del modelo.
- ☐ Solo se verifica el comportamiento del modelo en la fase de aceptación inicial.
- ☐ Una vez en producción, el modelo del proveedor no se monitoriza de forma específica.
- ☐ No hemos identificado el drift de modelos de IA como un riesgo de cadena de suministro.

BLOQUE VIII — Zero Trust y Acceso de Proveedores

Zero Trust no es desconfianza patológica. Es ingeniería preventiva con fundamento matemático. Y en la cadena de suministro, es casi la única apuesta racional disponible a coste razonable.

P8.1. ¿Su organización aplica principios de **Zero Trust** (nunca confíes, siempre verifica; mínimo privilegio; microsegmentación) al acceso de proveedores externos a sus sistemas?

- ☐ **L5** — Sí: Zero Trust está plenamente implementado para todos los accesos de proveedores con

verificación continua de identidad, mínimo privilegio y microsegmentación.

- [] **L4** — Zero Trust implementado para proveedores críticos; en proceso de extensión al resto.
- [] **L3** — Se aplican algunos principios Zero Trust (MFA, segmentación básica) pero sin arquitectura completa.
- [] **L2** — Los accesos de proveedores están controlados mediante VPN y controles perimetrales tradicionales.
- [] **L1** — Se está evaluando la implementación de Zero Trust para proveedores.
- [] **L0** — No se aplican principios Zero Trust; los proveedores acceden con credenciales estándar sin controles adicionales.

P8.2. ¿Se aplica el **principio de mínimo privilegio** a todos los accesos de proveedores externos a sistemas críticos?

- [] Sí, todos los accesos de proveedores están estrictamente limitados al mínimo necesario, con revisión periódica automatizada.
- [] Se aplica para los accesos más críticos, aunque no de forma universal.
- [] El principio está definido en la política, pero su aplicación práctica es inconsistente.
- [] Los proveedores tienen accesos amplios por comodidad operativa; las restricciones son mínimas.
- [] No aplicamos restricciones de privilegio específicas para proveedores.

P8.3. ¿Se registra y audita toda la actividad de los proveedores en los sistemas de la organización (logging completo, SIEM, monitorización de sesiones privilegiadas con PAM)?

- [] Sí, registro completo de sesiones integrado en el SIEM con alertas automáticas ante comportamientos anómalos.
- [] Sí, se registra la actividad, aunque sin análisis automatizado ni alertas en tiempo real.
- [] Se registra solo la actividad de los accesos más críticos.
- [] El registro existe, pero no se revisa sistemáticamente.
- [] No se registra ni audita la actividad específica de los proveedores.

P8.4. ¿Se revisan y revocan periódicamente las credenciales y accesos de los proveedores, especialmente al finalizar un contrato o al producirse cambios de personal en el proveedor?

- [] Sí, proceso automatizado de revisión y revocación vinculado al ciclo de vida del contrato y a los cambios de personal notificados.
- [] Sí, se revisan anualmente y se revocan cuando el proveedor nos notifica el cambio.
- [] Los accesos se revocan al terminar el contrato, pero no se gestionan los cambios de personal del proveedor.
- [] La revocación depende de que alguien recuerde hacerlo manualmente.
- [] Tenemos accesos de proveedores activos cuyos contratos finalizaron hace tiempo. *(Nota: esto constituye una vulnerabilidad crítica y auditable.)*

P8.5. ¿Dispone su organización de una solución de **Gestión de Accesos Privilegiados (PAM)** que cubra los accesos remotos de proveedores a sistemas críticos?

- [] Sí, PAM implementado para todos los accesos privilegiados de proveedores, con grabación de sesiones y alertas de comportamiento anómalo.

- [] PAM implementado para los sistemas más críticos; en proceso de extensión.
- [] Utilizamos controles básicos (MFA, VPN dedicada) pero sin PAM formal.
- [] Los accesos privilegiados de proveedores se gestionan con las mismas herramientas que los accesos internos.
- [] No disponemos de solución PAM específica para proveedores.

BLOQUE IX — Participación en Ecosistemas de Intercambio de Información

La inteligencia colectiva sobre amenazas es el único antídoto que escala al ritmo de los atacantes. Y, a diferencia de la mayoría de los presupuestos de ciberseguridad, no requiere tramitar un expediente de contratación.

P9.1. ¿Su organización participa en mecanismos formales de intercambio de información sobre ciberamenazas y vulnerabilidades en la cadena de suministro (ISACs, grupos de trabajo sectoriales, plataformas de inteligencia compartida)?

- [] Sí, participamos activamente en uno o varios ISACs o grupos sectoriales, contribuyendo con datos propios y consumiendo inteligencia compartida.
- [] Participamos como receptores de información, pero no contribuimos activamente con datos propios.
- [] Estamos valorando la participación en mecanismos de intercambio de información.
- [] No participamos por restricciones legales, de confidencialidad o falta de recursos.
- [] No conocemos los mecanismos disponibles de intercambio de información en nuestro sector.

P9.2. ¿Su organización tiene acuerdos formales de cooperación o de ayuda mutua en ciberseguridad con otras organizaciones del sector o con sus proveedores críticos? (*Indicador IMC A-PC-OE5-01*)

- [] Sí, existen acuerdos formales documentados de cooperación y ayuda mutua tanto con proveedores como con pares del sector.
- [] Existen acuerdos informales o de buena voluntad, sin formalización documental.
- [] Solo participamos en foros sectoriales promovidos por organismos públicos (CCN, INCIBE, DSN, Foro Nacional de Ciberseguridad).
- [] No existen acuerdos de cooperación; cada organización gestiona sus riesgos de forma independiente.
- [] Nos gustaría participar, pero no sabemos cómo articular ni formalizar estos acuerdos.

P9.3. ¿Utiliza su organización de forma sistemática las alertas, guías y avisos de seguridad publicados por las autoridades competentes (CCN-CERT, INCIBE-CERT, ENISA, CISA) en materia de riesgos de cadena de suministro?

- [] Sí, de forma completamente sistemática: las alertas se integran en el proceso de gestión de riesgos y se trasladan a los proveedores afectados cuando corresponde.
- [] Sí, seguimos las alertas, aunque no siempre se trasladan de forma proactiva a los proveedores.
- [] Las consultamos ocasionalmente, sin integración sistemática en los procesos internos.
- [] Recibimos las alertas, pero el volumen supera nuestra capacidad de procesamiento y priorización.
- [] No seguimos de forma regular las alertas de las autoridades competentes.

P9.4. ¿Participa su organización en las evaluaciones coordinadas de riesgo en la cadena de suministro promovidas por la Comisión Europea o el Grupo de Cooperación NIS2 para su sector? (*NIS2 Art. 22*)

- [] Sí, participamos activamente en las evaluaciones coordinadas de riesgo sectoriales.
- [] Seguimos los resultados de las evaluaciones coordinadas, pero no participamos directamente en su elaboración.
- [] No hemos sido convocados a ninguna evaluación coordinada de nuestro sector.
- [] No estábamos al corriente de la existencia de estas evaluaciones coordinadas.
- [] No aplicable para nuestro sector o tamaño organizativo.

BLOQUE X — Cumplimiento Normativo, Auditoría y Ciclo de Vida del Proveedor

El cumplimiento normativo es el suelo mínimo, no el techo de la ambición. Pero para muchas organizaciones, el suelo todavía está en obras.

P10.1. ¿Ha realizado su organización una evaluación formal (*gap analysis*) del grado de cumplimiento con la normativa aplicable en materia de CSCR (ENS RD 311/2022, NIS2/Anteproyecto de Ley de Coordinación y Gobernanza, DORA si aplica, Cyber Resilience Act)?

- [] Sí, mediante una evaluación formal exhaustiva con el marco normativo completo, informe documentado y plan de remediación priorizado.
 - [] Sí, pero limitada al ENS o a la normativa de un único regulador sectorial.
 - [] Se ha realizado una evaluación informal o parcial, sin informe documentado.
 - [] No se ha realizado ninguna evaluación formal de cumplimiento CSCR.
 - [] No tenemos claridad suficiente sobre qué normativa aplica exactamente a nuestra organización.
- (Nota: este punto puede resolverse consultando el FAQ NIS2 de INCIBE o contactando con el CCN-CERT.)*

P10.2. ¿Dispone su organización de un proceso formal de **gestión del ciclo de vida de los proveedores** que cubra de forma integrada las fases de selección, onboarding, monitorización continua y offboarding seguro?

- [] **L5** — Sí, proceso formal completo con procedimientos documentados, roles definidos y herramientas integradas para cada fase del ciclo de vida.
- [] **L4** — Existen procedimientos para la mayoría de las fases, aunque el proceso completo no está plenamente integrado.
- [] **L3** — El proceso existe en las fases de selección y onboarding; la monitorización y el offboarding son informales.
- [] **L2** — Solo gestionamos formalmente la fase de selección/contratación.
- [] **L1** — Se está diseñando el proceso de ciclo de vida.
- [] **L0** — No existe gestión formal del ciclo de vida de proveedores.

P10.3. ¿Su organización ha sufrido algún incidente de ciberseguridad en los últimos 24 meses cuyo origen o vector de entrada fuera un proveedor o tercero con acceso a sus sistemas?

- [] Sí, hemos sufrido uno o varios incidentes con origen confirmado en la cadena de suministro.
- [] Hemos detectado intentos o indicadores de compromiso originados en proveedores, sin materialización de incidente grave.
- [] No hemos detectado incidentes de este tipo (*aunque reconocemos que nuestra capacidad de detección puede ser mejorable*).

- ☐ No monitorizamos el origen de los incidentes de forma suficientemente granular.
- ☐ No hemos sufrido ningún incidente de ciberseguridad relevante en los últimos 24 meses.

P10.4. En caso de haber sufrido un incidente originado en un proveedor, ¿cuál fue el impacto principal?
(Puede seleccionar varias opciones)

- ☐ Interrupción del servicio o degradación operativa significativa
- ☐ Exfiltración de datos (datos de clientes, datos corporativos, propiedad intelectual)
- ☐ Cifrado de datos / ransomware
- ☐ Comprometimiento de credenciales o accesos privilegiados
- ☐ Daño reputacional con cobertura mediática
- ☐ Impacto económico directo (pérdidas, costes de recuperación, honorarios de respuesta)
- ☐ Sanciones regulatorias o requerimientos formales de autoridades supervisoras
- ☐ No hemos sufrido incidentes de este tipo
- ☐ Prefiero no responder

P10.5. ¿Cuáles son los tres marcos o normas que más influyen en el diseño del programa CSCRm de su organización? (Seleccione hasta 3)

- ☐ ENS RD 311/2022 (Esquema Nacional de Seguridad)
- ☐ NIS2 / Anteproyecto Ley de Coordinación y Gobernanza de la Ciberseguridad
- ☐ NIST SP 800-161r1 (C-SCRM)
- ☐ ISO/IEC 27001:2022 y familia 27036
- ☐ DORA (Digital Operational Resilience Act)
- ☐ IEC 62443 (entornos OT/industriales)
- ☐ Cyber Resilience Act (CRA)
- ☐ NIST Cybersecurity Framework 2.0 (función GV.SC)
- ☐ FAIR (cuantificación de riesgos)
- ☐ Diccionario IMC de INCIBE-CERT
- ☐ Cuestionario Unificado CCN-CERT / ISMS Forum Spain
- ☐ Reglamento DORA o TIBER-EU (sector financiero)
- ☐ Ninguno de los anteriores; seguimos metodología propia

BLOQUE XI — Madurez Global, Inversión y Prioridades Estratégicas

Al final de todo cuestionario serio llega el momento de la reflexión incómoda. ¿Estamos invirtiendo donde más duele cuando algo falla? ¿O donde más luce en la presentación del Comité de Dirección?

P11.1. En una escala del 1 al 10, ¿cómo valoraría la **madurez global** de su organización en la gestión de riesgos de ciberseguridad en la cadena de suministro?

- ☐ **1-2:** Prácticamente inexistente. Somos conscientes del problema, pero no hemos empezado a estructurar una respuesta.
- ☐ **3-4:** Inicial. Hay algunas prácticas aisladas, pero sin coherencia, cobertura ni responsable claro.
- ☐ **5-6:** En desarrollo. Existen procesos definidos para los aspectos más críticos, aunque con brechas relevantes.
- ☐ **7-8:** Avanzado. Tenemos un programa CSCRm estructurado con métricas y un plan de mejora

activo.

- [] **9-10:** Optimizando. El CSCRМ está plenamente integrado, medido cuantitativamente y sometido a mejora continua.

P11.2. ¿Cuál es el presupuesto anual dedicado a CSCRМ como porcentaje del presupuesto total de ciberseguridad de su organización?

- [] Más del 20%
- [] Entre el 10% y el 20%
- [] Entre el 5% y el 10%
- [] Menos del 5%
- [] No existe una partida presupuestaria específica para CSCRМ
- [] Desconocemos el desglose presupuestario con ese nivel de granularidad

P11.3. ¿Cuáles son los principales obstáculos que impiden a su organización mejorar su postura CSCRМ? *(Seleccione hasta 3)*

- [] Falta de presupuesto específico para CSCRМ
- [] Escasez de personal cualificado en ciberseguridad con experiencia en cadena de suministro
- [] Dificultad para supervisar a un número elevado de proveedores con los recursos disponibles
- [] Falta de estándares o guías claras y aplicables al contexto español
- [] Resistencia cultural o falta de concienciación en las áreas de negocio
- [] Complejidad de la cadena de suministro (múltiples niveles, subcontratistas, geografías)
- [] Falta de apoyo o implicación real de la Alta Dirección
- [] Incertidumbre regulatoria (NIS2 en transposición incompleta en España a abril 2026)
- [] Ausencia de herramientas adecuadas para la evaluación y monitorización de proveedores
- [] Resistencia de los propios proveedores a ser evaluados, auditados o a compartir información
- [] Otro (especifique): ____

P11.4. ¿Cuáles son las tres iniciativas CSCRМ que su organización considera **prioritarias para los próximos 12 meses?** *(Seleccione hasta 3)*

- [] Elaborar o actualizar el inventario de proveedores TIC con clasificación formal por criticidad
- [] Implementar el cuestionario de evaluación de proveedores (basado en modelo CCN-CERT/ISMS Forum u otro estándar)
- [] Incorporar requisitos de ciberseguridad en los contratos con proveedores (SBOM, PQC, plazos NIS2)
- [] Desplegar herramientas de monitorización continua o *security ratings* de proveedores
- [] Actualizar el Plan de Respuesta a Incidentes para incluir escenarios de cadena de suministro
- [] Realizar ejercicios de simulación (tabletop exercises) con participación de proveedores críticos
- [] Iniciar el análisis de inventario criptográfico y madurez PQC en la cadena de suministro
- [] Implementar arquitectura Zero Trust para el acceso de proveedores externos
- [] Participar en mecanismos de intercambio de información sectorial (ISACs, foros nacionales)
- [] Formar y concienciar al equipo de Compras / Aprovisionamiento en riesgos CSCRМ
- [] Incorporar requisitos de AIBOM para proveedores de sistemas con componentes de IA/ML
- [] Otro (especifique): ____

P11.5. ¿Estaría su organización dispuesta a participar en un programa piloto de **evaluación sectorial coordinada de CSCRМ** promovido por organismos públicos españoles (CCN-CERT, INCIBE, DSN, Foro Nacional de Ciberseguridad)?

- ☐ Sí, con entusiasmo. La colaboración público-privada es esencial para gestionar un riesgo de naturaleza sistémica.
- ☐ Sí, en función del alcance, las garantías de confidencialidad y el esfuerzo requerido.
- ☐ Posiblemente, si otros actores relevantes del sector también participan.
- ☐ No, por restricciones de confidencialidad o política corporativa.
- ☐ No lo consideramos una prioridad en el contexto organizativo actual.

P11.6. (*Campo abierto*) ¿Desea añadir algún comentario, reflexión, caso de uso o información adicional sobre la gestión de riesgos CSCRМ en su organización?

Espacio de texto libre — toda aportación es bienvenida y valiosa

Cierre y Agradecimiento

Gracias por su tiempo y por la honestidad de sus respuestas. En un mundo donde la cadena de suministro digital es el vector de ataque más frecuente y sistemáticamente subestimado, cada dato honesto es un avance colectivo. Sus respuestas contribuirán a construir el primer mapa sistémico de la madurez CSCRМ en España y a informar las políticas públicas y privadas del sector.

Fecha de cumplimentación: __

Organismo / Empresa: __ (opcional, si consiente identificación)

Correo para recibir el informe sectorial agregado: __

© 2026 · Encuesta CSCRМ España · Versión 1.0

Elaborada con base en: INCIBE-CERT IMC v2.8 · CCN-CERT/ISMS Forum Cuestionario Unificado (feb. 2025) · Foro Nacional de Ciberseguridad (sep. 2025) · ENS RD 311/2022 · NIST SP 800-161r1 · ENISA NIS Investments 2025 · ENISA NIS360 2025 · Cipher/Prosecur Supply Chain Report 2026 · CISA SBOM Minimum Elements 2025 · ACSC AI/ML Supply Chain Guidance oct. 2025